

Security is the main concern in the case of Web applications. Testing a product after deployment is a hard task.

DevSecOps is a process of integrating security measures into the DevOps process. The Software Development Life Cycle (SDLC) is introduced in DevSecOps to make applications very secure by using a variety of tools for different security concerns. Dynamic Application Security Testing or DAST is a security measure where Web applications are tested dynamically for vulnerabilities while still in production. This type of testing is also called 'black box testing' as it does not consider the internal infrastructure of applications but instead looks at an attacker's perspective. It is helpful to weed out vulnerabilities like SQL injection, cross-site scripting and even with some runtime problems like server issues and authentications. The DAST tool we have used for our experiment is called OWASP ZAP, which is one of the existing popular open source tools.

The system requirements are as follows.

- **OS version:** Kali Linux (with pre-installed security tools including OWASP ZAP)
- **RAM allocation:** Minimum of 4GB (in case of VM)
- **Installed Jenkins and Java 8 version**

Introduction to OWASP ZAP

Open Web Application Security Project Zaproxy (OWASP ZAP) is a popular DAST tool. It is used by most penetration testers for testing automation. We have used this tool for our Web application testing since it is easily integrated with Jenkins in the CI/CD pipeline with a plugin.

Integration with Jenkins

To automate the process of testing, we have integrated the OWASP ZAP tool with Jenkins using the tool's plugin. The steps for the process of integration are given below.

Official OWASP ZAP Jenkins Plugin

The **Official OWASP ZAP Jenkins Plugin** extends the functionality of the **ZAP** security tool into a CI Environment.

Figure 1: OWASP ZAP plugin in Manage Plugins

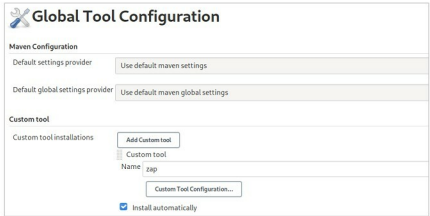


Figure 2: Custom tools in the Global Tool Configuration

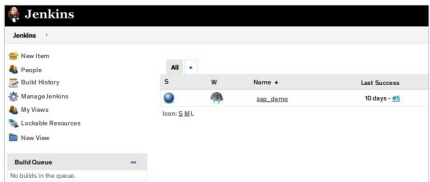


Figure 3: New freestyle project

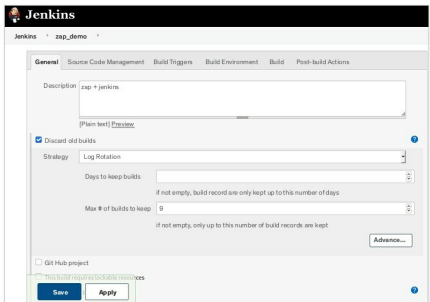


Figure 4: Configuration of the new project